

Secure Electronic Transaction

[SET]

Module 4

Prepared by

Jesna J S

Assistant Professor, CSE TKMCE

Contents Includes:

- Secure Electronic Transaction (SET)
 - ✓ Overview
 - ✓ Features
 - ✓ Participants
 - ✓ Dual signature
 - ✓ Payment processing.

Secure Electronic Transaction (SET)

- Secure Electronic Transaction (SET) is a security protocol developed by Visa and MasterCard in 1996 to ensure secure online credit card transactions over the Internet.

Table R.1 Important Security Requirements

<i>Requirement</i>	<i>Description</i>
Privacy	Information shared among the communicating parties must be known only to them. All others must be kept out of the loop.
Authentication	Both the communicating parties must be in a position to establish and prove their identities.
Integrity	The message that is transmitted by the sender should not be tampered. If tampered, the receiver must be in a position to identify the same and discard the message.
Non-Repudiation	Both the communicating parties must have the facility to legally prove that messages have been sent and received.

- It was designed to protect:
 - Cardholder information
 - Merchant information
 - Payment data during electronic commerce
- SET aims to provide:
 - Confidentiality of payment information
 - Authentication of cardholder and merchant
 - Data integrity
 - Non-repudiation
 - Secure authorization and payment processing

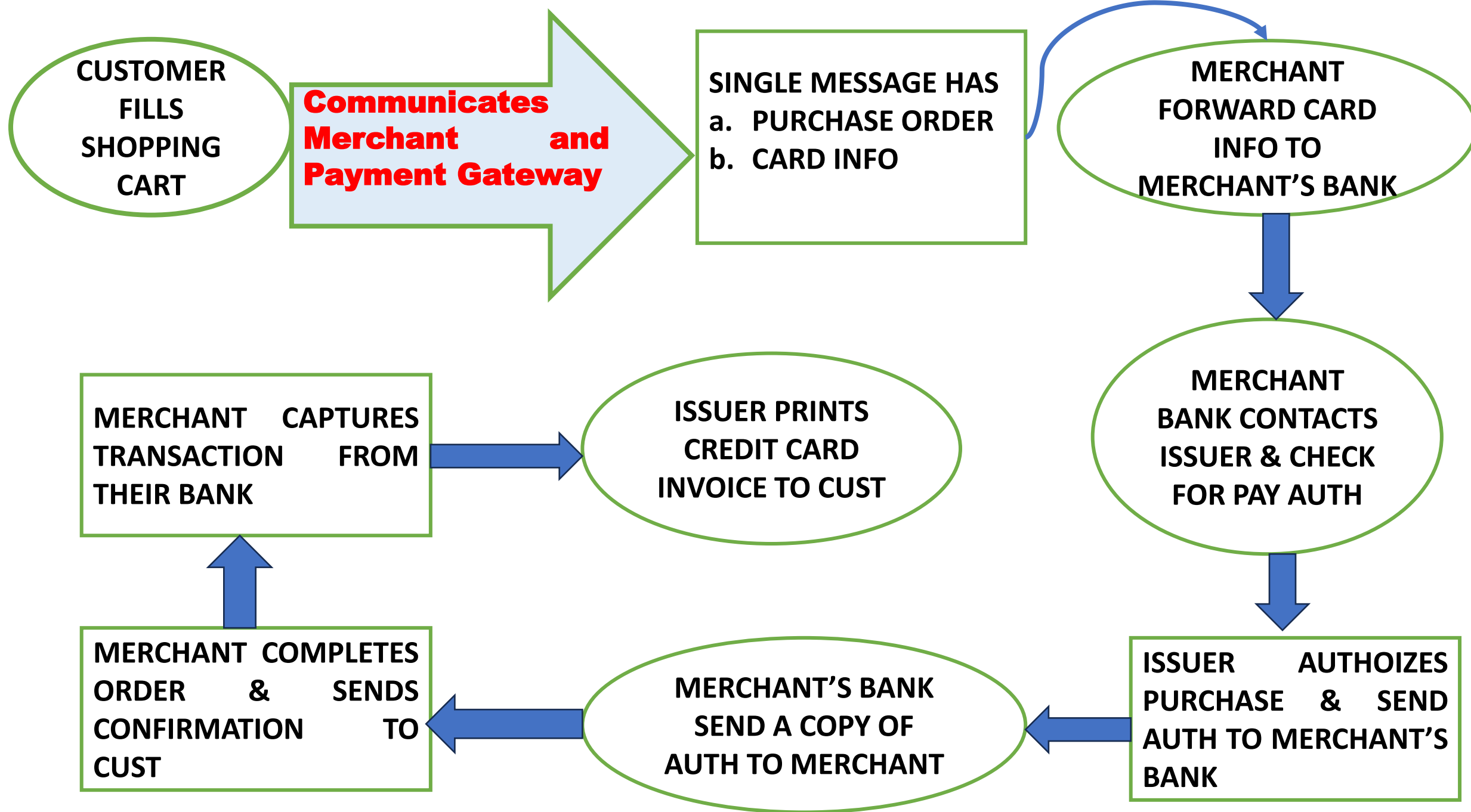
Table R.2 *Main Participants of the SET System*

<i>Participant</i>	<i>Details</i>
Cardholder	Refers to the person who holds the card and who makes the purchases on the Internet.
Merchant	A person or organization that has goods or services to sell to the cardholder.
Issuer	Refers to the financial institutions that provide the cardholder with the credit card and are responsible for the payment.
Acquirer	Refers to organizations that provide verbal or telephonic card authorization for merchants. Merchants pay a small fee to the acquirer for their services.
Acquirer Payment Gateway	Acts as an interface between SET and the computer networks of banks. To put it simpler terms, the acquirer payment gateway acts as a proxy for the bank's network functions.
Certifying Authority (CA)	Refers to the organization that provides public key certification. One of the best-known Certifying Authority (CA) is <i>Verisign</i> which offers several classes of certificates. Class 1 certificate is of the lowest level which binds e-mail address and associated public keys. Class 4 certificates are the highest level certificates that apply to servers and their organizations.

How SET Works?

- Before SET can work, there is a preliminary step which has to be completed.
- *Preliminary Step*: Both cardholders and merchants **must register with the CA (certifying authority)**.
- *Actual Steps in SET*
 1. Customer browses website of the merchant, **decides what to purchase and adds them to the shopping cart**.
 2. Customer then **communicates with the merchant and payment gateway in a single message**.
 - The message has two parts:
 - ✓ **Part a**: Purchase Order for use by the merchant.
 - ✓ **Part b**: Card Information for use by the merchant's bank.

3. **Merchant forwards the card information (part b) to their bank.**
4. **Merchant's bank contacts the issuer and checks with the issuer for payment authorization.**
5. **Issuer authorizes the purchase and sends authorization to Merchant's bank**
6. **Merchant's bank sends a copy of the authorization to merchant**
7. **Merchant completes the order and sends confirmation to the customer.**
8. **Merchant captures the transaction from their bank.**
9. **Issuer prints the credit card invoice to customer.**



Encryption Process in SET

- SET uses encryption mainly in **two places**:
 - ✓ **When the cardholder sends a purchase request**
 - ✓ **When payment information is sent to the payment gateway/bank**
 - Algorithm used:
 - ✓ RSA (1024-bit) → Digital signature & key encryption
 - ✓ DES (56-bit) → Data encryption
 - ✓ SHA-1 → Message digest
- Hash → Sign → Encrypt data → Encrypt key → Send.**

1. The sender creates a **message digest** using **SHA-1**.
2. The sender **encrypts** the digest using **RSA private key** to form a **digital signature**.
3. The sender generates a **symmetric key**.
4. The sender encrypts the **message, digital signature, and certificate using DES**.
5. The sender encrypts the **symmetric key** using the **receiver's RSA public key**.
6. The encrypted data and encrypted key are sent to the receiver.

Decryption Process in SET

- **Decrypt key → Decrypt data → Verify signature → Compare hash**

Algorithms Used :

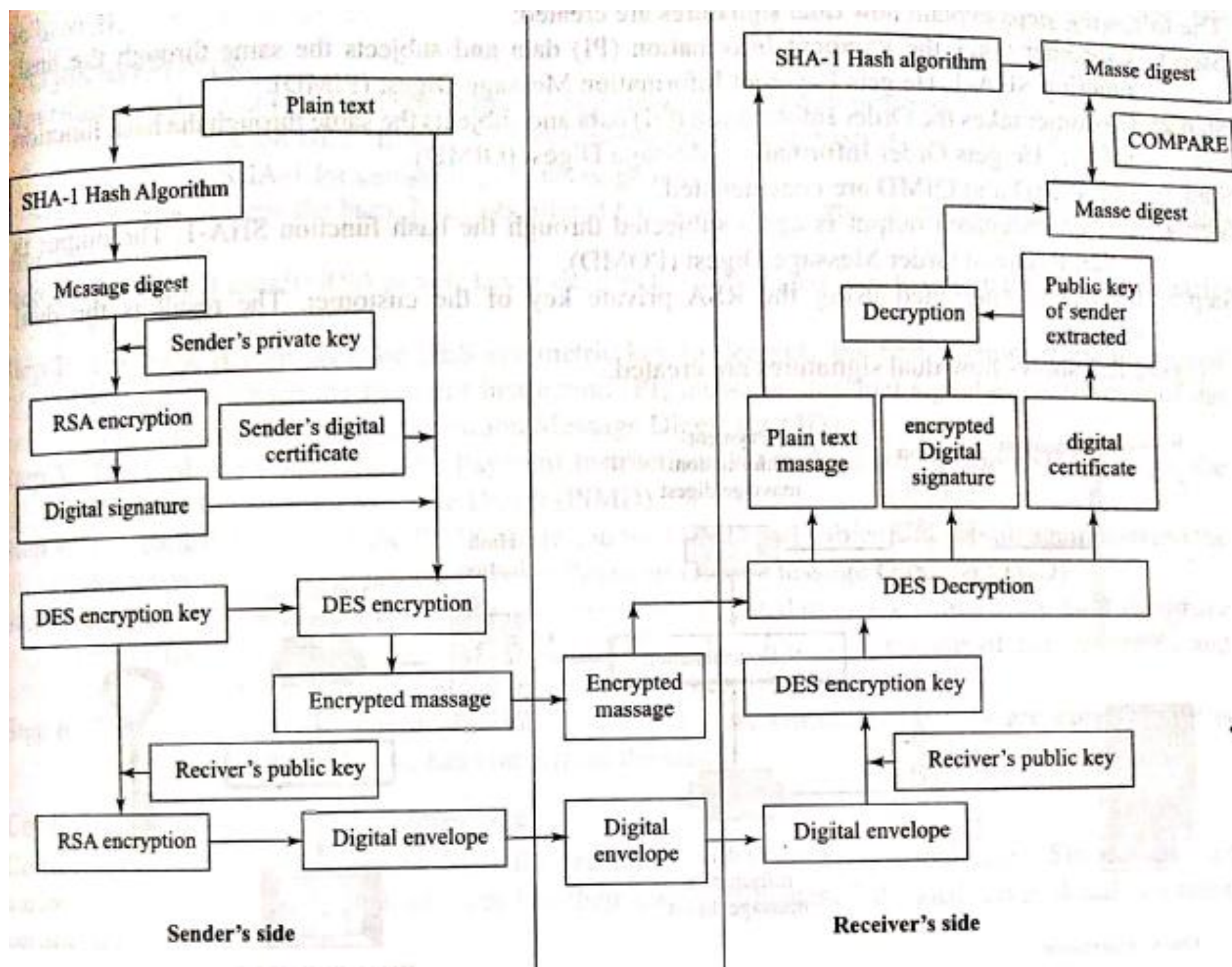
✓ **RSA (1024-bit) → Key decryption & signature verification**

✓ **DES (56-bit) → Data decryption**

✓ **SHA-1 → Message digest computation**

1. Receiver decrypts the encrypted DES key using RSA private key.
2. Receiver uses the DES key to decrypt the message.
3. Receiver obtains plain message, signature, and certificate.
4. Receiver gets sender's public key from the certificate.
5. Receiver decrypts the signature to get the message digest.
6. Receiver hashes the message using SHA-1.
7. Receiver compares both digests.
8. If they match, the message is authentic and unchanged.

Encryption Decryption Process



Dual Signatures

- In SET, the customer communicates with the merchant and the payment gateway through a single message.
- The message has two parts, a purchase order part for use by the merchant and a card information part for use by the merchant's bank.
- The customer has to ensure that,
 - ✓ **Merchant should NOT see card details.**
 - ✓ **Bank should NOT see order details.**
- **But both must be sure the data belongs to the same transaction.**
- This is achieved by a new concept introduced in SET named as **dual signature**.
- **Why is it called “Dual”?**
 - Because it is created using **TWO** hashes:
 - ✓ Hash of Order Information
 - ✓ Hash of Payment Information

How are Dual Signatures Created?

1. Customer takes the **Payment Information (PI)** data and subjects the same through the hash function SHA-1. He gets **Payment Information Message Digest (PIMD)**.
2. Customer takes the **Order Information (OI)** data and subjects the same through the hash function SHA-1. He gets **Order Information Message Digest (OIMD)**.
3. Both PIMD and OIMD are concatenated.
4. The concatenated output is again subjected through the hash function SHA-1. The output is called **Payment Order Message Digest (POMD)**.
5. POMD is encrypted using the **RSA private key of the customer**. The result is the **dualSignature**.

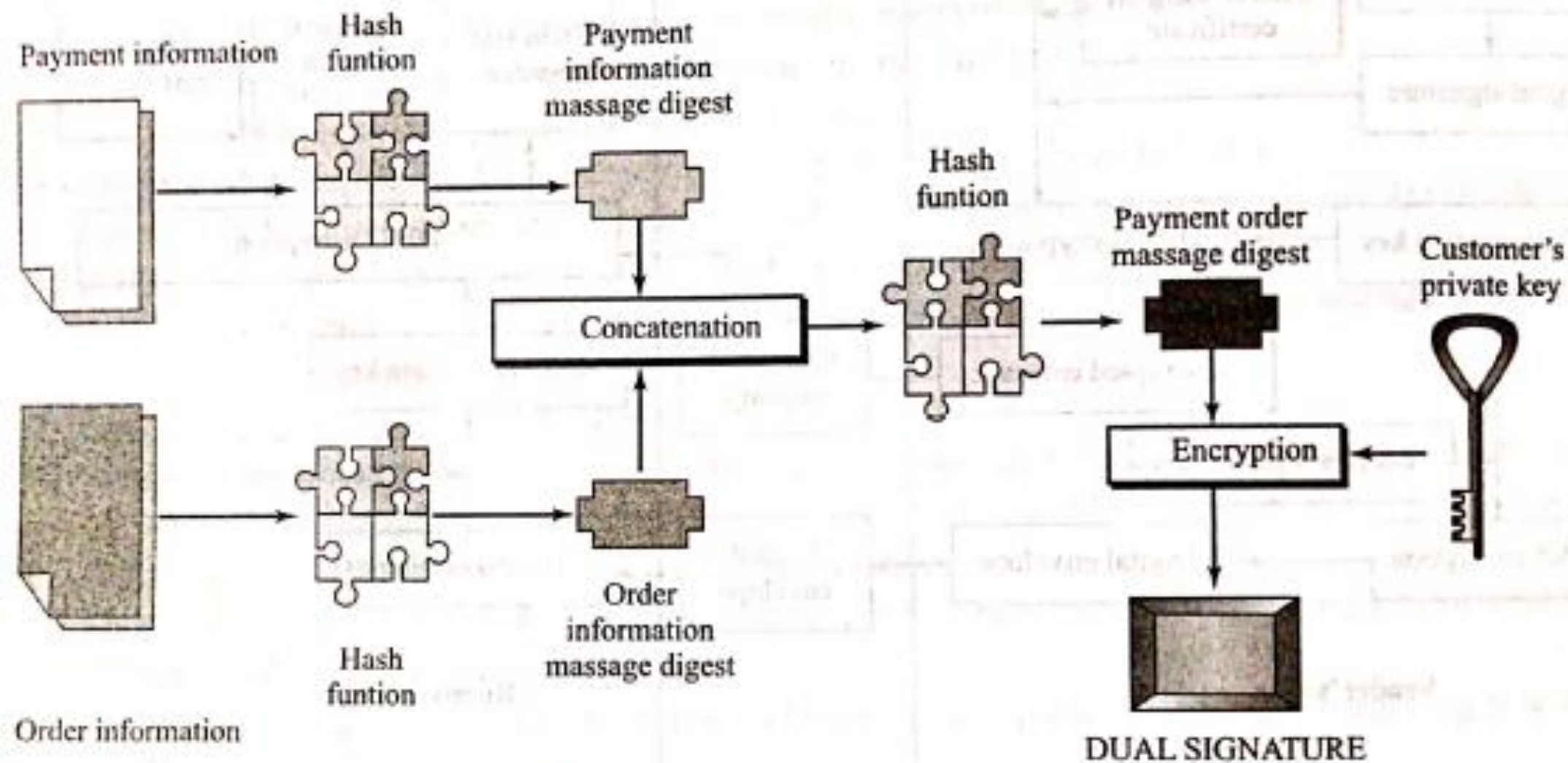


Fig. R.2 *How Dual Signatures are created*